

# Change record — P3 AD security assessment and privileged access hardening

Change record in the same shape Halden uses for every change (feeds the change log and the P10 governance dashboard). In a small company the same person often proposes and approves; that separation is documented honestly rather than pretended.

| Field                  | Value                                                                                                                                                                                                                                                                                       |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Change ID              | CHG-2026-004                                                                                                                                                                                                                                                                                |
| Title                  | P3 — Active Directory security assessment and privileged access hardening                                                                                                                                                                                                                   |
| Raised by              | IT (Muhammad Ibrahim Akmal)                                                                                                                                                                                                                                                                 |
| Approved by            | Managing Director ( <i>business owner of the fictional Halden; see the note on the lab</i> )                                                                                                                                                                                                |
| Date raised            | 2026-10-02                                                                                                                                                                                                                                                                                  |
| Planned implementation | Phase 0 → Phase 7, one phase per session                                                                                                                                                                                                                                                    |
| Category / risk        | Security — High risk (Tier 0: directory, authentication, domain controllers)                                                                                                                                                                                                                |
| Affected services      | Logon and Kerberos authentication, Group Policy, local administrator access to every endpoint, service authentication (SQL/app), file services, remote administration                                                                                                                       |
| Affected systems       | DC01, DC02, FS01, LNX01, WS01, WS02 (new PAW)                                                                                                                                                                                                                                               |
| Authorisation note     | The assessment uses attack-path tooling. Per AGENTS.md rule R6 it runs <b>only</b> inside this isolated lab, <b>only</b> against <code>ad.halden.internal</code> , and only after the owner's authorisation is recorded. Authorisation reference for this change: <code>CHG-2026-004</code> |

## 1. Description of the change

Assess the Active Directory environment with free, well-known tooling (PingCastle basic, Purple Knight, BloodHound Community Edition), record every finding in a risk-rated register, and remediate: enable the AD Recycle Bin, remove excess and stale privileged accounts, clear pre-authentication and delegation weaknesses, stop the Print Spooler on the domain controllers, raise the password policy with a stricter fine-grained policy for admins, deploy Windows LAPS with encrypted AD backup, build a three-tier privileged access model with logon restrictions and delegated helpdesk rights, replace legacy service accounts with gMSAs, and harden legacy protocols in an audit-then-enforce sequence. Re-assess afterwards and report the before/after comparison.

## 2. Reason for the change

Today one compromised workstation can plausibly reach domain control: the same local administrator password is used everywhere, IT uses a single Domain Admin account for all work including email, privileged group membership includes disabled and unused accounts, service account passwords are years old, and the domain accepts legacy protocols with a seven-character password policy. Credential abuse is the most common initial access vector in the current industry data (22% of breaches), and ransomware operators escalate to directory privileges first because that is what lets them encrypt every machine at once. This change removes the technical shortcuts that make that escalation easy.

### 3. Impact and risk

| Area              | Impact                                                                                                     | Mitigation                                                                                                                                   |
|-------------------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| IT staff          | Everyone in IT gains a second account and must change how they work                                        | Written standard, a short briefing, and the logon restrictions make the correct behaviour the easy one                                       |
| Users             | Lockout policy becomes stricter (10 attempts / 15 minutes); local administrator access is no longer shared | One-page note to staff via department heads; Service Desk briefed                                                                            |
| Authentication    | Kerberos, NTLM, LDAP signing and SMB signing changes can break old applications                            | <b>Audit</b> → <b>analyse</b> → <b>enforce</b> : NTLM (event 8004) and Kerberos RC4 (event 4769) are audited and reviewed before enforcement |
| Directory schema  | Windows LAPS extends the forest schema; that is not cleanly reversible                                     | DC01 and DC02 snapshotted together before the phase; recorded as an accepted one-way step                                                    |
| krbtgt            | A reset in the wrong sequence invalidates every ticket and causes an outage                                | <b>Not automated.</b> Performed as a separate scheduled change with the required wait between resets                                         |
| Privileged access | Deny-logon rules can lock out the wrong account                                                            | Break-glass Administrator excluded and stored offline; every rule tested before it is trusted                                                |
| Security tooling  | Assessment output describes how the domain could be attacked                                               | Tooling runs only in the isolated lab with authorisation; raw output never published; only sanitized summaries leave the evidence folder     |

### 4. Implementation plan (phases)

| Phase | Work                                                                                                              | Window       | Verification                                                 |
|-------|-------------------------------------------------------------------------------------------------------------------|--------------|--------------------------------------------------------------|
| 0     | Authorisation gate, encounter snapshots, and seed the realistic weaknesses the assessment must find               | Same evening | Gate passes; seed log written                                |
| 1     | Assess with PingCastle, Purple Knight and BloodHound CE; build the findings register; write the executive summary | Same evening | Before-value evidence captured with a source file            |
| 2     | Quick wins: AD Recycle Bin, Domain Admin cleanup, pre-auth and delegation cleanup, Spooler off, FGPP              | Out of hours | 11-Verify-Remediation.ps1<br>PASS rows                       |
| 3     | Windows LAPS: schema, delegated read, encrypted backup, DSRM for DCs                                              | Out of hours | Event 10018; helpdesk read succeeds, standard user denied    |
| 4     | Tiering: _Admin OUs, separate admin accounts, deny-logon GPOs, Protected Users, PAW, helpdesk delegation          | Out of hours | Denied RDP test with a Tier 0 account; delegation test       |
| 5     | Service accounts: gMSA, AES-only Kerberos after audit, krbtgt rotation planned                                    | Out of hours | Service account test succeeds; audit events reviewed         |
| 6     | Legacy protocols: LM level 5, SMB signing, SMBv1 off, LDAP signing and channel binding, LLMNR off                 | Out of hours | Audit events reviewed first; configuration verified per host |

| Phase | Work                                                                           | Window       | Verification                            |
|-------|--------------------------------------------------------------------------------|--------------|-----------------------------------------|
| 7     | Re-assess, before/after table, risk acceptance, monthly health check scheduled | Same evening | After-value evidence with a source file |

## 5. Test plan (acceptance)

1. The assessment gate passes, and every assessment script refuses to run without an authorisation reference.
2. A standard, non-IT user account cannot read a LAPS password; a helpdesk member can.
3. A Tier 0 administrator account attempting to sign in to WS01 is denied.
4. The helpdesk can reset a Sales user's password but cannot reset a Tier 0 administrator's password.
5. A Tier 0 human account signs in successfully with Protected Users membership in place.
6. Re-running every phase script produces no duplicates and no errors (idempotent).
7. The verification script reports PASS on every control the project claims.
8. Every metric in the README has a source file in `evidence/public/`.

## 6. Backout plan

Each phase is snapshotted before it runs ( `snap-p3-ph<N>-before` ; DC01 and DC02 together for the schema phase). Backout is to revert the snapshot and re-run the previous phase's scripts, which are idempotent. GPO changes back out by returning the settings to "Not Configured" and refreshing policy. **Exception:** the Windows LAPS schema extension cannot be undone by removing an attribute, and a `krbtgt` reset cannot be undone at all — both are handled as deliberate, separately approved changes with the risk written down here rather than discovered later.

## 7. Post-implementation review

To be completed when the last phase is verified: the actual global risk score reduction, the number of findings closed and accepted, the attack-path state before and after, anything that went wrong, and whether any phase overran. Results are recorded in `projects/p03-ad-security/README.md` , with a source file for every number.

Note: this is a home-lab change record for a fictional company (Halden Distribution Ltd.), written in an isolated lab. The technical content, scripts and measurements are real; the business approval line represents the lab owner's decision, not a real customer sign-off. The assessment tooling is run only against the lab domain and only with the owner's authorisation.